

RANSOMWARE ATTACK

Tabletop Exercise -- Complete Project Deliverable

Three Column Answer Comparison | Self Assessment Summary

Organization: Maplewood Regional Medical Center (Fictional)
Reference Framework: NIST SP 800-61 Rev 2 -- Computer Security Incident Handling Guide
UNCLASSIFIED // FOR TRAINING PURPOSES ONLY

Completed by: Elijah Marcisz | June 2026
Portfolio Project -- Cybersecurity GRC and Incident Response

EXERCISE SUMMARY

This document is the complete deliverable for a self-guided ransomware tabletop exercise conducted at Maplewood Regional Medical Center, a fictional 320-bed healthcare organization. The exercise consisted of five sequential injects walking through a LockBit 3.0 ransomware incident from initial detection through recovery and lessons learned. All responses were developed independently before being compared against guided best-practice answers aligned to NIST SP 800-61 Rev 2 and the HIPAA Breach Notification Rule.

EXERCISE ATTRIBUTE	DETAIL
Scenario	LockBit 3.0 Ransomware with Data Exfiltration
Organization	Maplewood Regional Medical Center (Fictional)
Role Played	IT Security Lead
Number of Injects	5 (Detection, Containment, Response, Notification, Recovery)
Primary Framework	NIST SP 800-61 Rev 2 -- Computer Security Incident Handling Guide
Secondary Framework	HIPAA Breach Notification Rule (45 CFR 164.400-414)
Threat Intelligence	MITRE ATT&CK mapped to each inject
Estimated Duration	90 minutes
Completed	June 2026

HOW TO READ THIS DOCUMENT

Each inject is presented with a three column comparison showing the progression of thinking across the exercise. The self assessment summary at the end captures the overall reflection and learning takeaways.

COLUMN LEGEND

Decision Point

Your Initial Answer

Your Developed Answer

Guided Response

WHAT THE THREE COLUMNS SHOW

The initial answer reflects baseline instincts before any coaching or documentation reference. The developed answer reflects how thinking sharpened through active reasoning and discussion. The guided response reflects best-practice aligned to NIST SP 800-61. The gap between initial and developed is the learning from this exercise. The gap between developed and guided is what to study next.

INJECT 1 | ANOMALOUS ALERT

Phase: Detection & Analysis Severity:
HIGH

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
What is your immediate first action in the next 15 minutes?	Review the raw logs and the information given in the alert. Understand what was triggered, what executed, what happened, why it was triggered, and what the effect was.	Pull the full event chain for MRMC-RAD-014 from the SIEM. Check the process tree, the parent process of the PowerShell execution, and any outbound connections in the EDR. Build a complete picture: what happened, what executed, what was the effect, and what is it trying to do.	Immediately triage the SIEM alert -- pull the full event chain for MRMC-RAD-014. Check process tree, parent process of PowerShell, and any outbound C2 connections in your EDR.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
Do you isolate MRMC-RAD-014 now, or gather more information first? Justify your answer.	Isolate it now because a lot is already happening and the attacker has already made it to the radiology system.	Isolate MRMC-RAD-014 now. SMB brute force combined with suspicious PowerShell are strong Indicators of Compromise. The cost of a false positive is a brief workstation disruption. The cost of waiting is potential ransomware spread across the network.	Isolate MRMC-RAD-014 from the network NOW. The combination of lateral movement attempts and suspicious PowerShell are strong IOCs. The cost of a false positive is far lower than allowing ransomware to spread.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
Who do you notify at this stage, and what do you tell them?	Notify the Compliance Officer and Incident Commander to determine whether it is an actual breach and escalate to separate authority. Tell them we have a potential breach and ransomware may have been injected into our system.	Notify the Incident Commander and loop in the Compliance Officer given the healthcare context. Keep it factual. Do not alert the full organization yet -- preserve investigation integrity and avoid panic. You can notify more than one person simultaneously.	Notify the IT Security Lead and Incident Commander immediately. Keep messaging factual. Do NOT alert the full org yet -- avoid panic and preserve investigation integrity.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
----------------	---------------------	-----------------------	-----------------

Is this a confirmed incident yet? What additional evidence would confirm it?	Not a confirmed incident yet but it can become one. A confirmed ransom note or popup demanding money would confirm it.	Not confirmed yet. What you have are strong Indicators of Compromise per 800-61 Section 3.2.2. Confirmation requires: ransomware binary identified, ransom note dropped, or active file encryption observed. Declare a suspected incident and treat it as real.	Not confirmed yet. Confirmation requires: ransomware binary identified, ransom note dropped, or encryption activity confirmed on files. Declare a suspected incident and treat it as real.
---	--	---	--

800-61 SECTIONS	Sec 3.2.2 (Signs of an Incident) Sec 3.2.6 (Incident Notification)
------------------------	---

INJECT 2 | RANSOMWARE CONFIRMED

Phase: Containment Severity: CRITICAL

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
What is your containment strategy? Be specific about network segmentation actions.	Sever all three additional workstations from the VLAN even without confirmed alerts because ransomware is already confirmed. Deploy decoy files and hidden folders as a detection layer.	Isolate the affected VLAN and sever all three additional workstations immediately. Block SMB traffic between VLANs at the firewall. Preserve a forensic image of MRMC-RAD-014 before wiping. Block outbound traffic to known LockBit C2 ranges. Decoy files are a strong preparation layer but the immediate priority is stopping the spread.	Segment aggressively: isolate the affected VLAN, block all SMB traffic between VLANs, pull the three additional workstations offline. Preserve forensic image before wiping. Block outbound traffic to known LockBit C2 ranges.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
Do you take Epic offline proactively? What are the patient safety implications?	Yes. The threat actor already has 40GB of data. The risk of ransomware reaching the EHR outweighs the disruption of taking it offline.	Yes -- take Epic to read-only or offline mode proactively. Activate paper-based clinical downtime procedures. Notify clinical leadership immediately. The CMO makes the final call on clinical operations, not IT.	Yes -- take Epic to read-only or offline mode as a precautionary measure. Patient safety comes first. Activate paper-based clinical workflows. Notify clinical leadership immediately.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
The threat actor claims data exfiltration. Does this change your HIPAA obligations right now?	Yes. The exfiltration claim triggers a breach assessment obligation and you need to begin documenting immediately.	Yes. Under HIPAA if PHI was accessed by an unauthorized party it is presumed a breach unless you can demonstrate low probability of compromise. Start documenting now and flag to the Compliance Officer.	Yes. The exfiltration claim triggers a potential HIPAA breach assessment. Begin documenting and start the breach assessment process now.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
Do you engage your cyber insurance carrier at this point? Why or why not?	Do not pay the ransom because it exceeds the insurance sublimit and you have offline backups as a recovery path.	Yes -- notify the cyber insurance carrier immediately. Most policies require prompt notification within 24-72 hours. Do not pay the ransom without their guidance -- the sublimit is \$1M against a \$2.3M demand.	Yes -- notify cyber insurance carrier immediately. They will assign an IR firm and legal counsel. Do NOT pay the ransom without legal and insurance guidance.

INJECT 3 | ESCALATION AND COMMUNICATIONS

Phase: Containment / Response Severity:
CRITICAL

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
How do you respond to the media inquiry right now?	The media inquiry is not the top priority. Call them back and say the hospital is handling operations and a cyberattack cannot be discussed at this time.	Route the media inquiry to the Communications Lead immediately. Provide a holding statement: MRMC is aware of a technical issue affecting some systems, patient care remains our priority. Do not confirm ransomware or disclose scope.	Issue a holding statement only. Do NOT confirm ransomware or disclose scope. Route all media inquiries to the Communications Lead.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
How do you handle the two surgeries requiring imaging? Who makes this call?	Use the backup systems to restore imaging and let the Chief Medical Officer make the call.	Escalate to the CMO immediately with options: transfer patients, physical film fallback, delay non-urgent procedures. The backup is 5 days old and may not contain today's scans. The CMO makes this call -- IT provides what is available, clinical leadership decides.	Escalate to the CMO immediately. Options: transfer patients, physical film fallback, delay non-urgent procedures. Patient safety overrides operational convenience -- the CMO makes this call, not IT.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
What is your recommendation to leadership on ransom payment?	Do not pay. It exceeds the insurance sublimit and you have offline backups as a contingency plan.	Do not recommend payment. Reasons: exceeds the \$1M insurance sublimit, offline backups provide a viable recovery path, payment does not guarantee decryption, OFAC sanctions risk applies, FBI recommends against payment.	Do NOT recommend payment. Payment does not guarantee decryption, backups exist, OFAC sanctions risk applies, insurance sublimit does not cover \$2.3M, FBI recommends against.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
----------------	---------------------	-----------------------	-----------------

Draft the key message points for an internal staff communication.	To all staff: we are currently experiencing a ransomware attack. My compliance and communications leads are regulating the issue. Do not click suspicious popups. Report suspicious workstation behavior immediately.	We are experiencing a cybersecurity incident affecting some systems. Response teams are actively working to resolve it. Do not click unusual links or popups. Report suspicious behavior to IT helpdesk. Follow department downtime procedures. Note: say cybersecurity incident not ransomware attack.	Key messages: cybersecurity incident in progress, patient care continuing, do not click unusual links or popups, report suspicious behavior to IT helpdesk immediately, follow downtime procedures.
800-61 SECTIONS	Sec 3.2.7 (Incident Prioritization) Sec 3.3.4 (Notifying External Parties) Sec 2.3.3 (Team Communications)		

INJECT 4 | BREACH DETERMINATION

Phase: Eradication / Notification Severity:
HIGH

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
Is this a reportable breach? Walk through the four-factor assessment.	Yes. Personal patient metadata was accessed from an external IP, forensics confirmed 6 hours of server access before encryption, backup restoration is underway, and no patient harm was documented.	Yes -- reportable breach. Four factors: (1) Nature and extent of PHI: names, DOBs, MRNs, diagnoses for 12,400 patients. (2) Who accessed it: unauthorized external threat actor. (3) Whether PHI was acquired: confirmed -- 38GB exfiltrated via SFTP. (4) Risk mitigation: partial -- data is in attacker hands. Presumption of breach is not overcome.	Yes -- reportable breach. All four factors weigh toward breach. Unauthorized external actor confirmed. 38GB exfiltrated. PHI of 12,400 patients. Presumption of breach stands.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
What are your notification obligations and timelines right now?	Speak to the Compliance Officer and Incident Commander within the next couple of hours. Loop in the CMO. Direct Communications Lead to notify media. Timelines not yet confirmed.	HIPAA requires: HHS OCR within 60 days, individual patient notification within 60 days, media notification required (breach exceeds 500 individuals), state notification within 30 days. Engage legal counsel immediately.	HHS OCR within 60 days. Individual notification within 60 days. Media notification required (12,400 exceeds 500 threshold). State notification within 30 days. Engage legal counsel immediately.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
What information do you need before notifying affected patients?	Need to know whose information was compromised and what was stolen. Would notify via automated email or voice message. Direct questions to the Communications Lead.	Before notifying patients: validated count of affected individuals, confirmed data elements exposed, patient contact information, legal reviewed notification letter, call center capacity, credit monitoring determination. HIPAA requires written notification by first class mail.	Validated patient list, confirmed data elements, legal reviewed notification letter, patient contact info, call center capacity, credit monitoring determination if financial data involved.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
----------------	---------------------	-----------------------	-----------------

How do you respond to the FBI's request for forensic artifacts?	Would not hand over everything immediately. Would provide the forensic analysis documents.	Cooperate fully with the FBI. Loop in legal counsel first. Do not destroy or alter any evidence. FBI involvement does not pause your HIPAA notification clock.	Cooperate fully. Loop in legal counsel first. Do NOT destroy or alter evidence. FBI involvement does not pause HIPAA notification obligations.
800-61 SECTIONS	Sec 3.2.5 (Documenting the Incident) Sec 3.3.3 (Eradication and Recovery) Sec 3.4 (Post-Incident Activity)		

INJECT 5 | RECOVERY AND LESSONS LEARNED

Phase: Post-Incident Activity Severity:
MEDIUM

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
What were the top three control failures that enabled this incident?	Lack of EDR on the victim workstation, macro execution enabled for a user with no business need, and unenforced MFA. All three allowed the attacker to gain access and move laterally.	Three failures each broke a different security layer: No EDR (detection layer failed), macro execution enabled (endpoint protection layer failed), unenforced MFA (access control layer failed). Defense in depth broke down at multiple points simultaneously.	Top 3: No EDR on victim workstation, macro execution enabled for non-approved user, no MFA on file server access. Each represents a different layer of defense in depth failing simultaneously.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
What are your top five immediate security improvements in the next 30 days?	Implement a security awareness training program, deploy EDR software across all workstations, and implement regular 24 hour backups.	Five improvements: Deploy EDR to 100% endpoint coverage, enforce MFA across all file server and remote access, disable macro execution via Group Policy, implement daily verified backups with immutable offline copies, launch a security awareness training program.	Deploy MFA, extend EDR to 100% coverage, disable macros via Group Policy, daily verified backups with immutable copies, security awareness training.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
How do you structure the lessons learned session to extract real learning without blame?	Focus on what was done correctly first such as having backups. Keep the conversation on systems and processes not individuals. The person who clicked the phishing email is not the problem -- the lack of technical controls is.	Run it blameless: start with what worked, walk the incident chronologically, ask what would have helped detect or respond faster not who made the wrong call. Hold the session within two weeks of incident resolution per 800-61 Section 3.4.1.	Blameless format. Focus on systems, processes, timelines not individuals. Walk the incident chronologically. Ask what would have helped, not who made the wrong call. Document formally per 800-61 Section 3.4.1.

DECISION POINT	YOUR INITIAL ANSWER	YOUR DEVELOPED ANSWER	GUIDED RESPONSE
----------------	---------------------	-----------------------	-----------------

What metrics will you track over the next 90 days to measure improvement?	Track MFA and EDR implementation, security awareness training completion, and backup protocol improvements.	Measurable metrics: Mean Time to Detect target under 1 hour, Mean Time to Contain target under 4 hours, EDR coverage 100%, MFA enrollment 100%, training completion rate, simulated phishing click rate post-training, backup RTO validated.	MTTD target under 1 hour, MTTC target under 4 hours, EDR coverage 100%, MFA enrollment 100%, training completion rate, backup RTO validated per 800-61 Section 3.4.2.
800-61 SECTIONS	Sec 3.4 (Post-Incident Activity) Sec 3.4.1 (Lessons Learned) Sec 3.4.2 (Using Collected Incident Data)		

SELF ASSESSMENT SUMMARY

The following reflects a post-exercise self assessment completed after reviewing all five inject responses against the guided answer key. Responses are recorded in the participant's own words.

REFLECTION AREA	YOUR NOTES
Where did my initial instincts consistently align with best practice?	My instincts were consistently strongest in two areas. First, technical isolation decisions -- every time the scenario presented an active threat I moved toward containment immediately: isolate the workstation, sever VLAN connections, take Epic offline. I did not hesitate or wait for more confirmation. Second, role-based escalation -- I consistently knew who owned what. Media goes to the Communications Lead, clinical decisions go to the CMO, breach determination involves the Compliance Officer. I was not trying to own the whole incident myself. My instincts were strongest on the organizational layer -- knowing who to talk to and who makes which call.
Where was the biggest gap between my initial and developed answers?	The biggest gap was in the procedures and processes that a professional would carry out in that work environment. I did not have experience dealing with situations like media inquiries, regulatory timelines, or formal notification procedures. I knew the right instinct -- for example not giving away too much to the media -- but I did not have the specific language, process, or formal structure that a professional would use. Mainly my gaps were in procedures and processes across everything, not in the judgment or the direction of my thinking.
Which 800-61 sections do I need to reread based on my gaps?	Section 2 (Preparation) -- I was contextually prepared because the scenario gave me information, but I lacked pre-built procedures. Reading Section 2 helps me recognize preparation failures in real engagements and recommend the right fixes. Section 3.3.3 (Eradication and Recovery) -- my containment instincts were strong but eradication is a different phase. The IAM backdoor in TTX 2 showed the difference between containing and fully eradicating. Section 3.4 and 3.4.1 (Post-Incident Activity and Lessons Learned) -- I understood the blameless concept intuitively but Section 3.4.1 provides the specific questions to use as a structured meeting agenda. Also Section 3.2.2 on indicators vs confirmed incidents.

What would I do differently in a real incident based on this exercise?	Three specific things would change. First, media handling -- before this exercise my first instinct was to tell the reporter about a cyberattack. Now my instinct is to give a technical issue holding statement, protect the narrative, and route to the Communications Lead. Second, log analysis -- before this exercise I would review logs generally. Now I would specifically look at the parent process, the event chain pairing, and check for C2 connections. I went from a general instinct to a specific triage methodology. Third, ransom payment reasoning -- my instinct was always no but now my reasoning is layered across insurance coverage, recovery plan viability, OFAC risk, and data exposure implications rather than just a gut refusal.
What do I need to study before my CC exam on June 26?	Two main areas. Business continuity procedures -- this came up directly in the healthcare scenario with downtime procedures, backup restoration timelines, and keeping operations running during an incident. Key concepts to know are RTO, RPO, and the difference between a business continuity plan and a disaster recovery plan. Network security -- my instincts were right throughout but the CC exam tests the underlying concepts behind those decisions: VLAN segmentation, DMZ, stateful vs stateless firewalls, and how network access controls relate to lateral movement. Also access controls from Domain 3 -- MFA, least privilege, and IAM concepts all showed up as control failures in both TTXs and are worth reviewing before Friday.
What do I want to focus on in the next TTX?	The next TTX is already built -- it is a phishing and credential compromise scenario at a corporate SaaS company (Nexus Technologies) where I play an external IR consultant. The focus will be on pure IR mechanics and network security with lighter regulatory depth, and the role shift from internal IT Security Lead to external consultant will change how I frame every decision. After completing that exercise the planned focus for future TTXs is insider threat scenarios and non-healthcare regulated environments.

PORTFOLIO NOTE

This tabletop exercise is part of a two-scenario IR consulting portfolio. The companion exercise covers a phishing and credential compromise incident at a corporate SaaS company (Nexus Technologies) with the participant playing the role of an external IR consultant. Together the two exercises demonstrate applied knowledge of NIST SP 800-61, HIPAA breach notification, MITRE ATT&CK; mapping, and consulting-level decision-making across healthcare and corporate environments.